Hands-On Pertemuan 2 - OWASP Top 10, Risk Mapping, dan HTTP Evidence

Mata kuliah TI215 Keamanan Aplikasi Web - Institut Teknologi Tangerang Selatan, 2026/2027 Ganjil

Nama	Farel Eka Saputra	NIM	1002250027
Prodi	Teknologi Informasi	Tanggal praktikum	16 Oktober 2026

Nama	Fauzan atillah	NIM	1002250039
Prodi	Teknologi Informasi	Tanggal praktikum	16 Oktober 2026

Nama	Hafiz Hablillah	NIM	1003250012
Prodi	Teknologi Informasi	Tanggal praktikum	16 Oktober 2026

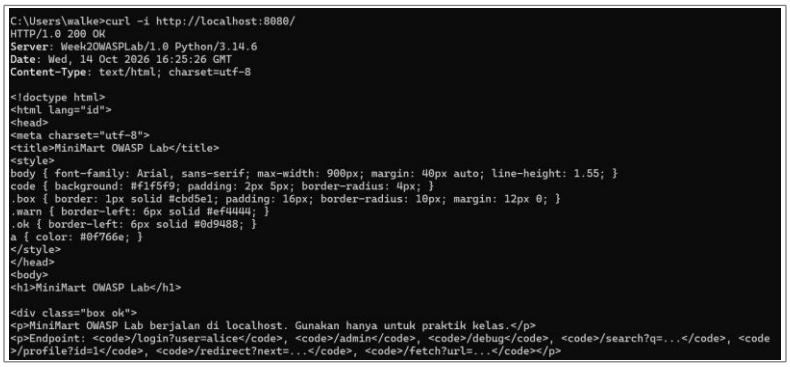
Lingkungan dan scope: Windows 11 (Command Prompt), Python 3.14.6, server MiniMart OWASP Lab. Seluruh pengujian hanya pada http://localhost:8080 (lab lokal); tidak ada pengujian ke LMS, SIAKAD, website kampus, maupun target pihak ketiga. Endpoint yang diuji: /, /login, /admin, /debug, dan /search.

Ringkasan Temuan

Praktik ini mengumpulkan evidence HTTP dari lima endpoint MiniMart memakai curl -i lalu memetakannya ke OWASP Top 10. Halaman utama merespons 200 OK tanpa satu pun security header (hanya Server, Date, Content-Type) dan membuka versi server pada header Server. /login membuat cookie username=alice; Path=/ tanpa atribut HttpOnly, Secure, maupun SameSite. /admin mengembalikan 200 OK tanpa cookie atau pengecekan role. /debug menampilkan konfigurasi internal dalam JSON. /search menampilkan kembali input tanpa output encoding: tag <b> yang dikirim muncul kembali sebagai tag HTML. Prioritas tertinggi adalah /admin (A01), karena paling mudah diakses dan berdampak langsung pada fungsi administratif.

1. Evidence HTTP Dasar - endpoint / (Evidence 1)

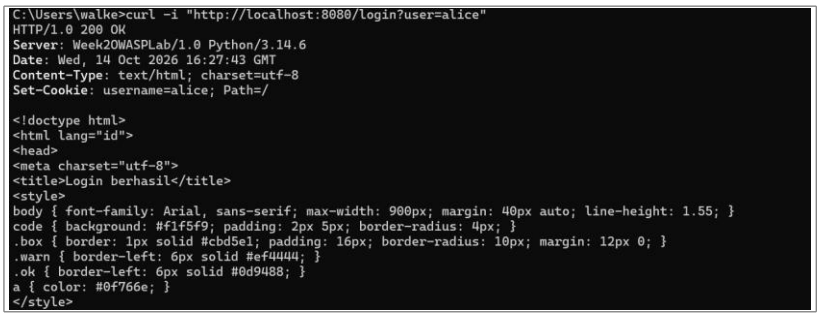
Perintah: python server.py, lalu di terminal baru curl -i http://localhost:8080/. Status HTTP/1.0 200 OK. Header yang terlihat hanya Server: Week2OWASPLab/1.0 Python/3.14.6, Date, dan Content-Type: text/html; charset=utf-8. Content-Security-Policy, X-Content-Type-Options, dan Strict-Transport-Security tidak ada, sedangkan header Server membocorkan nama aplikasi dan versi Python (A05).



Gambar 1 (Evidence 1). curl -i http://localhost:8080/: 200 OK, header Server membuka versi, tanpa security header.

2. Cookie dan Session - endpoint /login (Evidence 2)

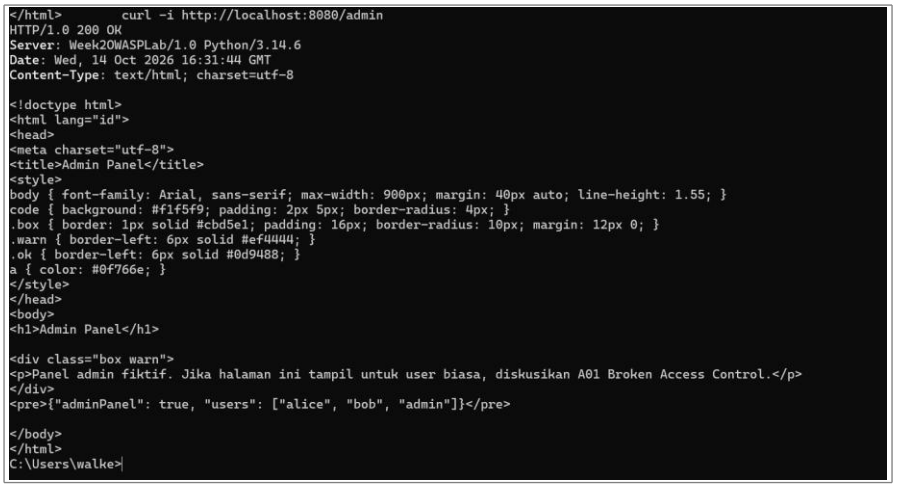
Perintah: curl -i "http://localhost:8080/login?user=alice". Response berisi Set-Cookie: username=alice; Path=/. Nama cookie adalah username dan nilainya langsung nama pengguna (bukan session id acak), sehingga mudah ditebak dan dipalsukan. Tidak ada atribut HttpOnly (cookie dapat dibaca JavaScript jika terjadi XSS), Secure (dapat terkirim lewat HTTP), maupun SameSite (risiko cross-site request). Kategori paling relevan: A07 Identification and Authentication Failures, didukung A05.



Gambar 2 (Evidence 2). Set-Cookie tanpa HttpOnly, Secure, dan SameSite.

3. Broken Access Control - endpoint /admin (Evidence 3)

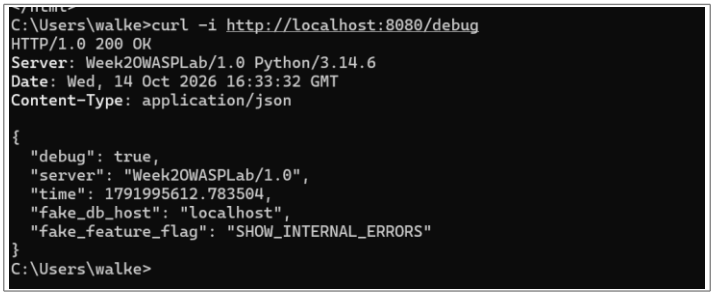
Perintah: curl -i http://localhost:8080/admin, dikirim tanpa cookie dan tanpa login. Server membalas 200 OK dan menampilkan "Admin Panel" beserta data {"adminPanel": true, "users": ["alice", "bob", "admin"]}. Artinya tidak ada pengecekan autentikasi maupun role di sisi server; siapa pun yang mengetahui URL dapat melihat panel admin dan daftar pengguna. Kategori: A01 Broken Access Control.



Gambar 3 (Evidence 3). /admin menjawab 200 OK tanpa login atau role admin.

4. Security Misconfiguration - endpoint /debug (Evidence 4)

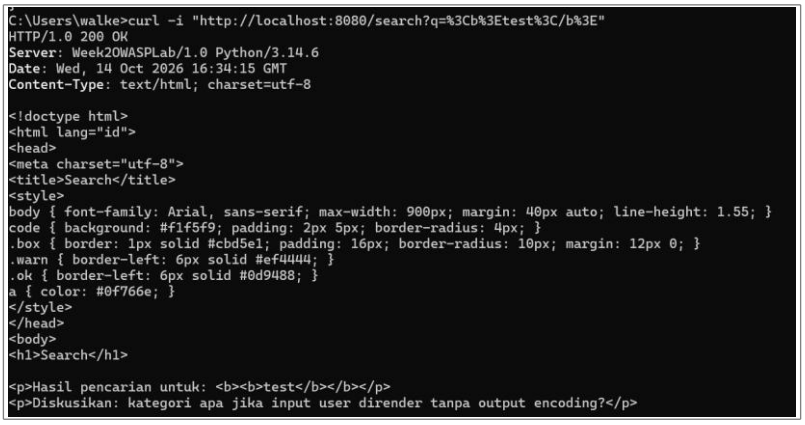
Perintah: curl -i http://localhost:8080/debug. Response bertipe application/json dan menampilkan "debug": true, "server": "Week2OWASPLab/1.0", timestamp server, "fake_db_host": "localhost", serta "fake_feature_flag": "SHOW_INTERNAL_ERRORS". Informasi ini seharusnya tidak tersedia untuk user umum karena membantu attacker mengenali teknologi, lokasi database, dan perilaku error aplikasi. Kategori: A05 Security Misconfiguration.



Gambar 4 (Evidence 4). Endpoint debug terbuka menampilkan konfigurasi internal dalam JSON.

5. Input Rendering - endpoint /search (Evidence 5)

Perintah: curl -i "http://localhost:8080/search?q=%3Cb%3Etest%3C/b%3E" (input test). Pada body tampil test: tag dari input tidak di-escape (tidak menjadi <), sehingga input diperlakukan sebagai markup, bukan teks. Pada kondisi ini payload script berpotensi menjadi reflected XSS; pada praktik ini hanya HTML sederhana yang diuji. Kategori utama: A03 Injection (XSS context), dengan A04 dan A05 sebagai bahan diskusi.



Gambar 5 (Evidence 5). Input tag HTML direnderer kembali tanpa output encoding.

6. Tabel Mapping OWASP

No	Endpoint	Evidence Teknis	Kategori OWASP	Dampak	Mitigasi Spesifik
1	/ dan /debug	200 OK tanpa CSP, X-Content-Type-Options, HSTS; header Server membuka versi (Gambar 1); JSON debug terbuka (Gambar 4)	A05	Informasi internal dan versi bocor; membantu pemetaan serangan	Nonaktifkan debug di production; hapus/samarkan banner Server; tambah security headers (CSP, nosniff, HSTS)
2	/login	Set-Cookie: username=alice; Path=/ tanpa HttpOnly, Secure, SameSite; nilai cookie = nama user (Gambar 2)	A07 (A05)	Session mudah dipalsukan dan disalahgunakan jika XSS atau jaringan tidak terenkripsi	Session id acak di server; set HttpOnly, Secure, SameSite=Lax/Strict; atur masa berlaku
3	/admin	HTTP 200 OK tanpa cookie/login; menampilkan adminPanel dan daftar user (Gambar 3)	A01	User biasa atau anonim dapat melihat panel admin	Authorization middleware per endpoint, cek role di server, deny by default, audit log
4	/search?q=	Input test kembali sebagai tag HTML tanpa escape (Gambar 5)	A03 (A04, A05)	Reflected XSS: pencurian cookie tanpa HttpOnly, defacement, phishing	Output encoding sesuai konteks HTML, template auto-escape, CSP sebagai defense-in-depth

7. Prioritas Risiko

Endpoint	Level	Alasan
/admin	High	Mudah direproduksi (satu request tanpa login), mengekspos fungsi dan data administratif; dampak langsung pada kerahasiaan dan integritas.
/login (cookie)	Medium	Atribut cookie tidak lengkap dan nilai mudah ditebak; berdampak besar jika digabung dengan XSS atau jika server menerima cookie username sebagai identitas.
/search	Medium	Input tidak di-escape; pada lab baru HTML sederhana yang terbukti. Naik ke High jika eksekusi script terbukti dan cookie dapat dibaca.
/debug dan header	Medium	Kebocoran informasi tidak langsung merusak data, tetapi mempermudah serangan lanjutan; perbaikan murah.

8. Rekomendasi Teknis

#	Masalah dan bukti	Tindakan	Validasi
1	/admin 200 OK tanpa role (Gambar 3)	Middleware autentikasi dan otorisasi pada semua endpoint sensitif; deny by default	curl -i /admin tanpa cookie mengembalikan 401/403; user biasa 403
2	Cookie username tanpa atribut (Gambar 2)	Ganti dengan session id acak; tambah HttpOnly, Secure, SameSite	Set-Cookie pada curl -i memuat ketiga atribut
3	/search tidak di-escape (Gambar 5)	Gunakan html.escape() atau template engine auto-escape; tambah CSP	Input tampil sebagai <b>
4	/debug terbuka dan header minim (Gambar 1, 4)	Matikan debug di production; tambah security headers; hapus versi pada header Server	/debug tidak tersedia; curl -i menunjukkan header lengkap

9. Refleksi

Bagian tersulit adalah membedakan evidence dari asumsi. Misalnya, pada /search yang terbukti hanya HTML sederhana yang dirender tanpa escape; eksekusi script belum diuji, sehingga dampak XSS penuh tetap berupa asumsi. Kategori juga bisa tumpang tindih (cookie lemah masuk A07 sekaligus A05), jadi kategori ditentukan dari akar masalahnya. Prioritas ditentukan dari dampak terhadap aset dan kemudahan penyalahgunaan, bukan dari nama kategori. Endpoint /profile, /redirect, dan /fetch tidak termasuk dalam evidence laporan ini.